CLIENT INTEGRATION SPECIFICATION

MEDSYS Backend Client Specification

Client-facing contract guide for the MEDSYS API Enterprise backend. This document summarizes the implemented API surface, authentication flow, authorization model, request and response conventions, and the integration rules frontend and client teams should follow.

DOCUMENT TYPE	SYSTEM
As-built client integration specification	MEDSYS API Enterprise Backend
VERSION	**DATE**
2.4	March 19, 2026
AUDIENCE	**SCOPE**
Frontend, BFF, QA, BA, and client delivery teams	Implemented REST contracts, auth behavior, permission model, and integration expectations

This document describes the current implemented backend behavior and replaces older role-only guidance for UI authorization decisions.

1. Purpose

This specification gives client teams one stable reference for how to integrate with the MEDSYS backend today. It focuses on implemented behavior rather than future proposals, so frontend and integration teams can build against the live contract without inferring rules from role names or older screenshots.

2. Integration Snapshot

AREA	CURRENT CONTRACT
Base API prefix	`/v1`
Primary content type	`application/json`
Access authentication	Bearer access token in the `Authorization` header.
Refresh flow	Refresh token is posted to `POST /v1/auth/refresh` to rotate and issue a new token pair.
Current-user endpoint	`GET /v1/auth/me` returns the authenticated user profile plus effective permissions.
Swagger UI	`/api/v1/docs` with request-body examples for implemented create and update flows.
Response style	JSON objects with snake_case for serialized fields such as `created_at`, `date_of_birth`, and `extra_permissions`.

3. Identity and Authorization Model

> **Important:** the backend no longer expects clients to derive permissions only from the role name. Role and permissions are separate concepts. UI decisions should follow the returned permission list.

CONCEPT	MEANING	CLIENT IMPACT
role	Primary user identity such as `owner`, `doctor`, or `assistant`.	Use for labeling workspace identity and user-management summaries, not as the only authorization source.
permissions	Effective allowed actions for the current user.	Use this array to decide which screens, buttons, and flows should be available.
extra_permissions	Per-user permission overrides stored on the user account. These are currently supported for selected doctor accounts only.	Useful for admin views and auditability, but UI authorization should still rely on the resolved `permissions` array.

3.1 Effective Permission Resolution

The backend resolves a user's effective permissions centrally as:

`effective permissions = role base permissions + extra_permissions`

This means a doctor can stay a doctor while receiving controlled per-user permission additions on top of the base doctor workflow. The system does not model this as two concurrent roles.

3.2 Assistant-Support Permission Subset

Owners can currently grant the following extra permissions to doctor accounts:

- `family.write`
- `inventory.write`

Doctors now receive `patient.write`, `appointment.create`, and `prescription.dispense` by default as part of the base doctor workflow. Owner-only permissions such as user administration or audit access are not part of this model and should not be expected on doctor accounts.

4. Authentication and Session Contracts

ENDPOINT	PURPOSE	CONTRACT NOTES
`POST /v1/auth/login`	Authenticate and issue tokens	Returns `accessToken`, `refreshToken`, `expiresIn`, and a `user` object that includes `role`, `permissions`, and `extra_permissions`.
`POST /v1/auth/refresh`	Rotate refresh token	Use when the access token expires. The refreshed response also returns the current permission set.
`GET /v1/auth/me`	Load current session profile	Frontend should call this after app bootstrap or session restore and treat it as the source of truth for permissions.
`POST /v1/auth/logout`	Revoke active refresh tokens	Authenticated route.
`GET /v1/auth/status`	Bootstrap status	Unauthenticated helper for initial setup state.
`POST /v1/auth/register`	Create a user or bootstrap first owner	Supports standard user creation and doctor accounts with optional extra permissions beyond the default doctor workflow.

4.1 Login Response Shape

```
{
  "accessToken": "eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...",
  "refreshToken": "eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...",
  "expiresIn": 900,
  "user": {
    "id": 12,
    "name": "Support Doctor",
    "email": "doctor-support@example.com",
    "role": "doctor",
    "permissions": [
      "appointment.read",
      "appointment.create",
      "appointment.update",
      "encounter.read",
      "encounter.write",
      "inventory.read",
      "patient.read",
      "patient.write",
      "prescription.read",
      "prescription.dispense"
    ],
    "extra_permissions": [
      "inventory.write"
    ]
  }
}
```

4.2 Frontend Authorization Rule

Frontend clients should render actions based on the returned `permissions` array. A doctor must still appear as a doctor in identity displays, and optional extra permissions should only expand that base workflow.

5. User Management Contract

ENDPOINT	PURPOSE	CONTRACT NOTES
`GET /v1/users`	List users	Returns each user with `role`, `permissions`, and `extra_permissions`.
`POST /v1/users`	Create user	Supports both frontend-style `name` payloads and direct API `firstName/lastName` payloads. Owners can create a doctor with

ENDPOINT	PURPOSE	CONTRACT NOTES
		allowed optional extra permissions such as `inventory.write` or `family.write`.
`PATCH /v1/users/:id`	Update activation or extra permissions	Used by owners to activate or deactivate users and to grant or clear the remaining allowed doctor extra-permission subset.

5.1 Example Permission Assignment

```
{
  "extraPermissions": [
    "inventory.write",
    "family.write"
  ]
}
```

Only valid permission names are accepted. Unsupported permission names or owner-only permissions are rejected by the backend.

6. Domain Endpoint Summary

DOMAIN	PRIMARY ROUTES	KEY PERMISSIONS	NOTES
Patients	`/v1/patients`	`patient.read`, `patient.write`, related history, allergy, condition, vital, and timeline permissions	`GET /v1/patients` is a summary-list contract. Full identity and guardian details belong to `/v1/patients/:id/profile`. Doctors can perform patient registration under the default doctor workflow.
Families	`/v1/families`	`family.read`, `family.write`	Doctor accounts can receive `family.write` through assistant-support permissions.
Appointments	`/v1/appointments`	`appointment.read`, `appointment.create`, `appointment.update`	Appointment creation is no longer tied only to the assistant role. It follows permission checks.
Encounters	`/v1/encounters`	`encounter.read`, `encounter.write`	Doctor base permissions already cover clinical encounter authoring.
Prescriptions	`/v1/prescriptions`	`prescription.read`, `prescription.dispense`	Doctors can access the pending dispense queue and complete dispense workflow under the default doctor permission set.
Inventory	`/v1/inventory`	`inventory.read`, `inventory.write`	Mutation routes are permission-checked; selected doctors can inherit inventory write access.
Clinical lookup	`/v1/clinical`	`clinical.icd10.read`	Reference read flows for ICD-10 search.
Analytics	`/v1/analytics`	`analytics.read`	Operational dashboards and cache metrics.
Audit	`/v1/audit`	`audit.read`	Reserved for users with audit visibility, typically owners.
Search	`/v1/search`	`patient.read`	Patient search surface with accelerated and fallback behavior.

7. Validation and Data Rules Important to Clients

- Patient `first_name` and `last_name` are required. Therefore the stored generated `full_name` is also never null.
- Patient `dob` is required and `age` is also required. The backend derives and validates age against DOB when provided.
- Patient `nic` is optional. The backend now assigns every patient a mandatory `patient_code` used as the always-available internal identifier.
- Patient API responses use snake_case fields such as `patient_code`, `date_of_birth`, `family_id`, `guardian_patient_id`, and `created_at`. Clients should not rely on temporary camelCase response fields.
- Minor patients without a patient NIC must include guardian information. Clients can either link an existing guardian with `guardianPatientId` in the write payload or provide guardian name plus guardian NIC or phone.
- Guardian-aware patient write payload fields supported by create and update flows are `familyId`, `familyCode`, `guardianPatientId`, `guardianName`, `guardianNic`, `guardianPhone`, and `guardianRelationship`.
- Patient create supports `bloodGroup` and inline `allergies` in both request styles. Allergy rows use `allergyName`, `severity`, and `isActive`, where severity must be `low`, `moderate`, or `high`.
- If neither `familyId` nor `familyCode` is provided on patient create, the backend auto-creates a family named from the patient, such as `Nimal Perera Family`.
- `priority` remains an appointment-only field. Clients should send visit urgency to `POST /v1/appointments`, not to the patient master record.

- `PATCH /v1/patients/:id` is transactional for patient profile, family, and allergy changes. If any part of a combined update fails, the full save is rolled back.
- User creation supports two request shapes: frontend-friendly `name` or direct API `firstName/lastName`.
- Swagger examples are available on the major create and update endpoints to reduce ambiguity around payload shapes.
- Permission names are validated. Clients should not send arbitrary strings in `extraPermissions`.

8. Recommended Frontend Behavior

1. Load `GET /v1/auth/me` on session restore and keep the returned `permissions` list as the UI authorization source.
2. Use `role` for display identity and workspace semantics, not for allow-or-deny logic.
3. Hide or disable create, update, dispense, and inventory mutation actions when the required permission is absent.
4. Expect a doctor with assistant-support permissions to remain `role = doctor`.
5. Use `GET /v1/patients` for summary lists, `GET /v1/search/patients` for doctor fast-selection by patient/guardian identity (returns `patient_code`, `nic`, `gender`), and `GET /v1/patients/:id/profile` after selection for full demographic and guardian details.
6. Do not assume patient NIC is always present in list responses or even on the patient record. For minors, use guardian-aware search and treat `patient_code` as the always-available identifier.
7. Use Swagger examples as the canonical request-body reference when onboarding client teams.

9. Doctor-Only Clinic Mode Workflow

For small practices operating without an assistant, doctors now possess native permissions to complete the full patient journey end-to-end:

1. Doctor searches patient using `GET /v1/search/patients` by code, NIC, phone, or name.
2. If not found, doctor creates the patient profile with `POST /v1/patients`, optionally including blood group, family link or family code, guardian details, and inline allergies.
3. Doctor creates or continues an appointment with `POST /v1/appointments` to trace the visit and assign `priority`.
4. Doctor enters the full profile (`GET /v1/patients/:id/profile`) and authors the clinical encounter.
5. If dispensing inside the clinic, doctor optionally completes the dispense workflow directly.

9. Source Basis

- Repository implementation state as of March 19, 2026.
- Auth and user management contract including effective permission responses and user-level permission overrides.
- Patient summary/profile separation, patient code identifiers, guardian-aware registration, and current database constraints through Flyway V10.
- Verified automated backend suite status of 53 passing API tests and 6 passing worker tests.

This document is the maintained client-facing reference for the implemented MEDSYS backend contract as of March 19, 2026.